CrossData Compliance

Sistema de Control de Protección de Datos Transfronterizos

Informe técnico-jurídico del prototipo académico

Caso 7: «Un clic, cuatro países y un dato que no debía cruzar la frontera»

AndeClass - educación digital y servicios cloud

Versión de entrega: 18 de octubre de 2026

Este documento describe un prototipo funcional con datos ficticios. El análisis organiza preguntas, controles y evidencia; la conclusión sobre una operación real requiere revisión del responsable. El informe académico es una descripción fija de la entrega. El reporte de la aplicación refleja el estado actualizado de los registros.

Idea central

TRATAMIENTO > JURISDICCIÓN > FINALIDAD > BASE > TRANSFERENCIA > RIESGO > CONTROL > EVIDENCIA

El valor del sistema es hacer visible la relación entre una decisión y su respaldo. La matriz internacional y el incidente de 320 titulares son las dos demostraciones principales; el laboratorio permite explorar sus causas mediante escenarios interactivos.

01. Problema, contexto y propósito

El caso AndeClass

Una startup peruana ofrece una plataforma a universidades. Recoge identificación, contacto, ubicación aproximada e historial académico. Un módulo de bienestar incorpora información de salud. Parte del procesamiento ocurre con un proveedor cloud en Estados Unidos; hay estudiantes temporalmente en España y una expansión prevista a México y Colombia.

La dirección propone reutilizar todos los datos para analítica, publicidad y recomendaciones. Al mismo tiempo, a las 10:15 se conoce que un archivo de prueba con nombres, correos y salud de 320 usuarios quedó visible en Internet. El problema exige investigar tanto la exposición como las decisiones previas sobre finalidad, acceso y transferencia.

Problema que aborda el prototipo

Una lista de tratamientos aislada no permite demostrar por qué se eligió una base, qué regla se revisó en cada país, quién asumió una decisión o qué documento respalda un control. CrossData conecta estos elementos y conserva los pendientes, en lugar de ocultarlos tras un indicador favorable.

Objetivo general

Permitir identificar, controlar y demostrar documentalmente las revisiones de protección de datos asociadas a operaciones internacionales del Caso 7.

Objetivo específico	Resultado observable
Identificar contexto	Inventario con datos, finalidad original, nuevo uso y países asociados.
Justificar por jurisdicción	Revisión de aplicabilidad, base y condición para salud, con responsable y evidencia.
Gestionar exposición	Incidente por etapas, decisiones por país, plazos fundamentados y respaldo de acciones.
Facilitar aprendizaje	Simulador que cambia alertas y compara revisiones documentadas.
Demostrar trazabilidad	Riesgo vinculado a control y evidencia; auditoría y exportaciones.

Actores y alcance

Administrador configura y mantiene registros; Cumplimiento documenta evaluaciones y acciones; Auditor consulta y exporta. Los titulares, universidades y proveedor son actores del caso, sin portales propios en esta versión. Se cubre la gestión de cumplimiento de una organización ficticia; no se integra correo, autoridad pública, nube real ni asesoría jurídica automatizada.

02. Funcionalidades y diseño técnico

Requisito del caso	Implementación	Evidencia de funcionamiento
Inventario de datos y usos	Tratamientos con categoría, países y finalidades.	Formularios, relaciones y alertas de salud/nuevo uso.
Matriz internacional	Fila por tratamiento y país; estado explicado.	Motivos, acciones pendientes, referencia normativa y revisión humana.
Transferencias	Origen, destino, proveedor, mecanismo y respaldo.	Identificación de garantía desconocida y revisión del riesgo.
Riesgos y controles	Probabilidad por impacto y vínculo explícito a controles.	Cadena de riesgo, control y evidencia del mismo ámbito.
Evidencias	Referencia documental y adjuntos PDF, PNG, JPG o TXT.	Descarga autenticada, autor, fecha y huella SHA-256.
Respuesta a incidente	Ocho etapas y decisiones separadas por jurisdicción.	Bloqueo de avance ante revisión pendiente o respaldo insuficiente.
Derechos y rendición de cuentas	Solicitudes, respuestas, auditoría y reportes.	Exportación CSV, reporte imprimible e informe académico descargable.
Interactividad	Tres escenarios y campos editables en laboratorio.	Alertas inmediatas; ensayo guardado y exportable.

Arquitectura

El navegador presenta Jinja, Bootstrap y JavaScript. Flask valida sesiones, permisos, relaciones y reglas. SQLAlchemy persiste entidades en SQLite. Waitress sirve la aplicación en la dirección local 127.0.0.1:5000. Las bibliotecas de interfaz están incluidas para que la demostración funcione sin conexión, salvo la consulta de fuentes externas.

Decisiones de integridad

Una evidencia debe corresponder al tratamiento y al país que se evalúan. Cargar un nuevo archivo devuelve la evidencia a «En revisión». La huella permite comparar contenido, pero no certifica su autoría ni veracidad. Los adjuntos se limitan a 1 MiB; se comprueba el formato básico y se sirven como descarga.

Las revisiones almacenan una huella del contexto. Si cambia un dato relevante del tratamiento o incidente, la evaluación se presenta como desactualizada. El servidor vuelve a calcular cada simulación antes de guardarla; el resultado no depende de un valor favorable enviado desde el navegador.

03. Matriz normativa: operación y receptor

Las normas siguientes orientan la revisión. Su aplicabilidad se fundamenta para cada tratamiento; el país de alojamiento no determina por sí solo todos los regímenes. Las fuentes oficiales están enlazadas en la sección 09.

Jurisdicción y alcance	Revisión requerida	Evidencia propuesta para el caso
Perú: organización de origen. Ley 29733 y reglamento. [1, 2]	Finalidad, proporcionalidad, consentimiento o excepción; protección de salud; información y derechos; garantías del flujo transfronterizo.	Inventario, aviso, justificación de base, autorización cuando corresponda, contrato y evaluación del proveedor.
España / UE: justificar primero el ámbito del RGPD. [3, 4]	Art. 3; base del art. 6 y condición del art. 9 para salud; nuevo uso, transparencia y derechos; encargo y transferencia internacional.	Análisis de alcance, fundamento de base, condición especial, avisos, garantía de transferencia y evaluación de medidas.
Estados Unidos: receptor cloud del caso. [5]	Identidad y rol del receptor, subencargados, ubicación y acceso; mecanismo permitido desde cada origen. No presumir una garantía válida para todo proveedor.	Contrato, localizaciones, listado de subencargados y comprobación del mecanismo concreto.

Aplicación al mismo dato

Un dato de salud usado para acompañamiento estudiantil conserva su sensibilidad si se reutiliza para publicidad. El cambio de finalidad exige analizar de nuevo la necesidad y el fundamento del uso. Exportarlo a un proveedor agrega una evaluación de destinatario y garantías; no sustituye la revisión de la finalidad.

Alcance territorial que debe defenderse

La presencia temporal de estudiantes en España es una señal para investigar. El equipo debe documentar establecimiento, oferta de servicios o seguimiento de comportamiento y su conexión con el tratamiento. No basta escribir «hay un usuario en España» para cerrar el análisis del artículo 3. [3, 4]

Cómo se representa en la aplicación

La matriz diferencia base general y revisión por jurisdicción. Abrir el estado muestra controles pendientes, responsables, transferencias y evidencia. El responsable registra alcance, base, condición para datos sensibles y conclusión. La etiqueta «Cumple» es una evaluación de apoyo sujeta a estos registros; no constituye una certificación legal.

04. Matriz normativa: expansión y controles

Jurisdicción prevista	Obligaciones que deben revisarse antes de operar	Evidencia y autoridad de referencia
México: particulares. LFPDPPP vigente, texto oficial reformado el 14-11-2025. [6]	Aviso de privacidad, consentimiento y excepciones; requisitos para sensibles; seguridad, derechos ARCO y transferencias.	Aviso adaptado, autorización cuando corresponda, procedimiento ARCO y acuerdo con receptor. La ley identifica a la Secretaría Anticorrupción y Buen Gobierno; verificar competencia para la operación concreta.
Colombia: Ley 1581 de 2012 y desarrollo aplicable. [7, 8]	Autorización y finalidad; tratamiento de sensibles; consultas y reclamos; distinguir transferencia y transmisión internacional.	Autorización, política, canal de atención, análisis del receptor y contrato según roles. Referencia institucional: Superintendencia de Industria y Comercio.

Plan de controles para AndeClass

Riesgo del caso	Control propuesto	Respaldo verificable
Archivo público con salud	Restringir acceso, separar pruebas y producción, minimizar datos de prueba.	Captura de permisos, registros y comprobación de acceso denegado.
Reutilización indiscriminada	Aprobación por finalidad; limitar el uso mientras falta revisión.	Análisis de compatibilidad o nueva autorización, alcance y responsable.
Transferencia sin garantía revisada	Evaluar receptor, roles, contrato y mecanismo por origen.	Contrato y análisis documentado del flujo concreto.
Atención de derechos incompleta	Canal, responsable, plazo y respuesta respaldada.	Expediente de solicitud y constancia de respuesta.
Pérdida de trazabilidad	Historial de cambios y relación riesgo-control-evidencia.	Registro anterior/nuevo y expediente exportado.

Criterio de salida

La expansión proyectada no se presenta como operación ya autorizada. Debe existir una revisión de alcance y un responsable antes de dar por concluido un requisito. Un contrato genérico, una captura de pantalla o una casilla marcada no prueban por sí solos todos los controles de la organización.

05. Incidente de los 320 titulares

Hechos, preguntas y decisiones

El archivo expuesto contiene nombres, correos y salud. La ausencia de contraseñas no elimina la afectación. La investigación debe determinar duración, accesos, copias, alcance real, medidas de protección y consecuencias para las personas. Se debe preservar evidencia de la exposición y de la contención.

Etapa	Acción demostrable	Condición de avance en el prototipo
Detectar / Contener	Registrar conocimiento y restringir exposición.	Nota de actuación; mantener hechos y responsables.
Evaluar / Registrar	Investigar personas, datos, países y consecuencias.	Descripción y registro de la acción.
Revisar obligaciones	Decidir por país sobre autoridad y titulares.	Aplicabilidad, fundamento y decisiones completas; plazo si se notifica.
Notificar	Documentar comunicaciones que correspondan.	Evidencia validada de tipo Notificación por país cuando procede.
Corregir / Cerrar	Comprobar corrección y dejar resultado.	Evidencia validada y trazabilidad del cierre.

Revisión peruana

El art. 34 del D.S. 016-2024-JUS contempla notificar a ANPD dentro de 48 horas desde conocimiento o constancia en los supuestos indicados, entre ellos datos sensibles. Haber subsanado internamente no elimina esa obligación. Deben revisarse también las comunicaciones adicionales aplicables en entorno digital y al titular. El equipo debe registrar el supuesto y la hora inicial; no trasladar un plazo extranjero por analogía. [2]

Revisión europea

Si el RGPD resulta aplicable, la notificación a la autoridad y la comunicación a los titulares tienen umbrales distintos. El art. 33 establece la referencia de 72 horas y su excepción por improbabilidad de riesgo; el art. 34 examina el alto riesgo para las personas. También debe documentarse la brecha. El formulario mantiene decisiones independientes y exige fundamento. [9, 10]

Regla de la demostración

Los plazos son ingresados y explicados por el responsable, con referencia horaria de Lima. El sistema no determina automáticamente la autoridad competente ni envía avisos. México y Colombia se incorporan a la revisión del incidente si aparecen personas u operaciones afectadas; la mera expansión prevista no se trata como afectación probada.

06. Laboratorio interactivo y trazabilidad

Una interacción que explica decisiones

El usuario modifica tratamiento, tipo de dato, país de origen, finalidad original, finalidad propuesta, destino y mecanismo. El resultado muestra alertas, riesgo inicial orientativo y revisiones que faltan documentar. Las reglas son explícitas; no se usa un modelo de IA para emitir conclusiones jurídicas.

Ensayo guiado	Qué se cambia	Qué se observa
Salud a publicidad	Salud, nueva finalidad y transferencia a EE. UU.	Revisión reforzada, mecanismo pendiente y análisis de alcance europeo.
Bienestar a cloud	Mantener finalidad y revisar destino internacional.	Persisten las revisiones de salud, transferencia y seguridad.
Uso académico	Historial académico, mismo uso y mismo país.	Menos revisiones derivadas del escenario; base y seguridad siguen presentes.

Comparación antes y después

El contador representa revisiones documentadas en el ensayo, no un porcentaje de cumplimiento. Una revisión seleccionada cuenta únicamente con evidencia validada del mismo ámbito y un fundamento. Para transferencia también debe identificarse el mecanismo. Una misma evidencia puede servir como referencia del ejercicio, sin que la aplicación afirme que su contenido prueba todos los requisitos.

El ensayo puede guardarse con título, autor y resultado; después se consulta o exporta. No cambia la matriz operativa ni reduce automáticamente riesgos reales. El botón de reinicio restablece el formulario del laboratorio.

Secuencia para exponer en 8 a 10 minutos

1. Presentar AndeClass y el incidente desde el dashboard; distinguir controles evaluados de cumplimiento.

2. Abrir el laboratorio y comparar salud/publicidad con uso académico. Explicar por qué cambian las revisiones.

3. Documentar un ensayo con referencia ficticia y mostrar el antes/después y el guardado.

4. Abrir una fila de matriz: dato, finalidad, país, bloqueo, responsable y evidencia.

5. Mostrar el incidente: 320 titulares, decisiones por país y bloqueo mientras falta información.

6. Recorrer riesgo, control y archivo adjunto; terminar en auditoría y reporte.

Frase de defensa: «Podemos explicar qué se revisó, por qué falta una decisión y qué respaldo necesitamos. Un indicador favorable sin evidencia no resolvería el caso».

07. Respuestas a las preguntas críticas

¿Qué obliga a distinguir dato, sensibilidad, finalidad y transferencia?

El nombre y el correo identifican a la persona; el historial de salud incorpora una condición que merece protección reforzada. El propósito de acompañar al estudiante difiere de usar esa información para segmentar publicidad. El procesamiento por un proveedor extranjero introduce receptor, roles y garantías adicionales. Son dimensiones independientes: el mismo archivo puede plantear preguntas diferentes en cada una.

¿Qué revisar de «aceptó términos, podemos usar todo»?

La afirmación omite el alcance de lo informado y autorizado, la base aplicable, la necesidad de cada dato y el propósito del nuevo uso. Para el caso, la propuesta prudente es suspender la reutilización comercial de salud mientras se documenta su viabilidad. El equipo debe explicar qué dato necesita cada función y registrar la decisión por jurisdicción. Una aceptación genérica no reemplaza esa evaluación.

¿Qué evidencia exigir antes de mantener producción?

Un expediente mínimo del caso debería reunir: inventario actualizado; análisis de alcance y base; revisión de finalidad secundaria; identificación y evaluación del proveedor; prueba de permisos corregidos; registros de investigación; decisiones de notificación y sus constancias cuando correspondan; canales de derechos y aprobación del responsable con pendientes explícitos.

¿Basta con borrar el archivo?

Retirarlo puede contener una exposición, pero no determina si hubo descargas ni repara copias existentes. También puede destruir evidencia si no se preserva correctamente. Se deben investigar alcance y consecuencias, documentar las decisiones aplicables, verificar la corrección y evaluar las causas que permitieron usar datos sensibles en pruebas. El prototipo obliga a pasar de una acción técnica a un expediente de respuesta.

¿Por qué un mismo dato tiene reglas distintas?

Cambian el contexto de la organización, la finalidad, las personas involucradas, los roles y el país de destino. El sistema no duplica una conclusión universal: permite justificar la aplicabilidad y la base en cada combinación de tratamiento y jurisdicción. Las referencias sirven para sostener el razonamiento, no para sustituirlo.

08. Validación, límites y conclusiones

Verificación de software

La suite automatizada pasó 30 pruebas con SQLite en memoria. Incluye los tres roles, autenticación, CSRF, formularios, relaciones, auditoría, CSV, matriz, incidentes, archivos y laboratorio. Se comprobó que cambiar el contexto invalida revisiones previas y que una evidencia de otro ámbito no se acepta. El aviso de permisos de caché de pytest no afectó la ejecución de las pruebas.

En navegador se comprobó el cambio de escenarios, el contador antes/después con fundamento y evidencia, y el guardado de un ensayo. Se revisó el laboratorio a 390 x 844, sin desbordamiento horizontal del documento. Estas verificaciones demuestran comportamiento funcional local; no equivalen a una auditoría de seguridad ni a una certificación jurídica.

Límites conocidos

- Las reglas de riesgo son académicas y simplificadas. Identificar salud por texto y una categoría manual no cubre todas las situaciones posibles.

- La revisión humana puede ser incorrecta; guardar un fundamento no demuestra su calidad jurídica. Los adjuntos requieren lectura crítica.

- La comprobación básica de archivos no incorpora antivirus ni análisis profundo. El almacenamiento y las credenciales demo son para uso local con datos ficticios.

- La auditoría es de solo lectura en la interfaz, pero alguien con acceso a SQLite puede alterarla. No hay sello de tiempo externo.

- No hay integración con autoridades, notificaciones reales, validación criptográfica de contratos ni monitoreo automático del proveedor.

- El informe académico es estático; para las decisiones actuales se debe generar el reporte desde la aplicación.

Conclusiones

CrossData transforma el Caso 7 en una cadena verificable de datos, decisiones y evidencias. La matriz explica el estado de cada combinación; el incidente obliga a distinguir países y destinatarios; el laboratorio ayuda a comprender qué cambia al modificar el uso del dato.

La mejora principal es que los pendientes permanecen visibles. Las revisiones favorables requieren respaldo y contexto vigente. Para una operación real aún se necesitarían revisión jurídica especializada, validación de seguridad, gobierno de accesos, conservación, respaldo, migraciones y procedimientos organizativos efectivos.

Recomendación para la entrega

Presentar el prototipo, este informe y una demostración breve que termine con decisiones pendientes justificadas. La calidad del trabajo se apoya en explicar el caso y mostrar evidencia; no en afirmar que todos los países o tratamientos ya cumplen.

09. Fuentes oficiales y materiales

Consulta de referencia: 18 de octubre de 2026. Los enlaces son verificables y se incluyen para que el responsable contraste el texto y su aplicación. No se reproducen extensamente las normas.

[1] Congreso del Perú. Ley 29733, Ley de Protección de Datos Personales.

Abrir fuente oficial

[2] Diario Oficial El Peruano / Congreso del Perú. D.S. 016-2024-JUS, reglamento de la Ley 29733, artículo 34.

Abrir fuente oficial

[3] Unión Europea. Reglamento (UE) 2016/679, RGPD.

Abrir fuente oficial

[4] AEPD. ¿A quién se aplica el RGPD?

Abrir fuente oficial

[5] AEPD. Garantías para las transferencias de datos personales.

Abrir fuente oficial

[6] Cámara de Diputados de México. Ley Federal de Protección de Datos Personales en Posesión de los Particulares.

Abrir fuente oficial

[7] SIC de Colombia. Ley Estatutaria 1581 de 2012.

Abrir fuente oficial

[8] SIC de Colombia. Normas Corporativas Vinculantes; distinción transferencia y transmisión.

Abrir fuente oficial

[9] AEPD. Brechas de datos personales: notificación.

Abrir fuente oficial

[10] AEPD. Comunicación de brechas de datos a los afectados.

Abrir fuente oficial

Materiales de la entrega

Código y pruebas en la carpeta del proyecto; guion en docs/GUIA_EXPOSICION.md; verificación en docs/VERIFICACION.md; texto editable del informe en docs/INFORME_ACADEMICO.md. El PDF se regenera mediante docs/generar_informe.py con ReportLab. El contenido del caso procede de las imágenes de la consigna proporcionadas por el estudiante.